

Dokümanın Adı:
RİSK YÖNETİMİ PROSEDÜRÜ

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: RYB.PR01	İlk Yayın Tarihi 9.10.2018	Revizyon Tarihi 9.10.2018	Revizyon No: 0	Sayfa Sayısı: 1/19
--	---------------------------------------	---	--	---------------------------------	-------------------------------------

REVİZYON TARİHÇESİ

Revizyon No	Revizyon Tarihi	Açıklama
0	9.10.2018	

Hazırlayan: RİSK YÖNETİMİ BİRİMİ	Süreç Sahibi: RİSK YÖNETİMİ BİRİMİ BELİRSİZ	EYS Onayı ENTEĞRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Onaylayan / İdari YÖNETİM KURULU
--	--	--	--

Doküman No
RYB.PR01.0

9.10.2018

1. AMAÇ

Bu prosedürün amacı; Posta ve Telgraf Teşkilatı Anonim Şirketi'nde şirketin, faaliyetlerinin kapsamı ve yapısıyla uyumlu ve değişen koşullara uygun, maruz kalınabilecek tüm risklerin tanımlanmasını, ölçülmesini, analiz edilmesini, izlenmesini, kontrol edilmesini ve raporlanmasını sağlayacak etkin bir risk yönetimi sistemi kurmasına yönelik uygulanacak prensipler ile ilgili usul ve esaslar ile yetki ve sorumlulukları belirlemektir.

2. KAPSAM

Bu prosedür; Posta ve Telgraf Teşkilatı Anonim Şirketinin tüm birim ve çalışanlarını kapsar.

3. TANIMLAR VE KISALTMALAR

- 3.1. Amaç:** Şirketin erişmeye çalıştığı uzun dönemli genel sonuçtur. Strateji oluşumuna temel teşkil eder ve planların gerçekleştirilmesinde yol göstericidir.
- 3.2. BGYS:** ISO 27001 Bilgi Güvenliği Yönetim Sistemidir.
- 3.3. Birim:** Komite/Kurul, Başkanlık, Müşavirlik, Daire Başkanlığı, Birimler, Özel Kalem Müdürlüğü ve Başmüdürlükleri ifade eder.
- 3.4. Birim Üst Yöneticisi:** Merkez teşkilatında Komite/Kurul Başkanını, Başkanı, 1. Hukuk Müşavirini, Daire Başkanını, Birim Sorumlusunu ve Özel Kalem Müdürünü; taşra teşkilatında ise Başmüdürü ifade eder.
- 3.5. ÇYS:** ISO 14001 Çevre Yönetim Sistemidir.
- 3.6. Doküman:** Bir faaliyeti ve o faaliyetin gereklerini tanımlayan veya belgeleyen yazılı, görsel ya da elektronik iç ve dış kaynaklı araçlardır.
- 3.6.1.Dış Kaynaklı Doküman:** PTT A.Ş. tarafından oluşturulmamış ancak PTT A.Ş.'nin faaliyetlerini etkileyen, uyulması zorunlu veya ihtiyari olan kanun, kanun hükmünde kararname, tüzük, yönetmelik, şartname, tebliğ, standart, esas, kılavuz vb. dokümandır.
- 3.6.2.İç Kaynaklı Doküman:** PTT A.Ş. tarafından oluşturulan QDMS El Kitabı, Organizasyon El Kitabı, Politika, Görev Tanımı, Usul ve Esaslar, Talimat, Rehber, Plan, Tablo, Liste ve Formlardan oluşan dokümandır.
- 3.6.2.1. Organizasyon El Kitabı:** Organizasyon yapısını, personelin görev tanımları ve niteliklerini tanımlayan dokümandır.
- 3.6.2.2. Politika:** Şirketin misyon vizyonuna ilişkin stratejik planla ilişkilendirilmiş üst yönetimce onaylanan dokümandır.
- 3.6.2.3. Görev Tanımı:** PTT A.Ş.'de İnsan Kaynakları tarafından belirlenmiş olan görev başlıklarında sorumlu olduğu pozisyonun tanımını, kapsamını ve uygulamadaki akışını düzenleyen dokümandır.
- 3.6.2.4. Talimat:** Bir uygulamanın basamaklarının kısa ve açık olarak belirtildiği dokümandır.
- 3.6.2.5. Rehber:** Süreç ve faaliyetlerin standart hale getirilmiş yöntemler kullanılarak gerçekleştirilmesini sağlamak amacıyla hazırlanan dokümandır.

- 3.6.2.6. Plan:** Bir süreç için uygulanacak faaliyetleri, hedefleri, hedeflere ulaşmak için kullanılacak yöntem ve unsurları, işlem sıralarını, bu faaliyetlerin kontrol metodlarını, özelliklerini, kaynak ve ekipman ihtiyaçlarını, uygunsuz sonuçla karşılaşıldığında uygulanacak işlemleri gösteren dokümandır.
- 3.6.2.7. Tablo:** Bilgi, durum tespit ve takip amacıyla oluşturulan dokümandır.
- 3.6.2.8. Liste:** Şirket faaliyetlerinin uygulanmasında oluşturulan sıralı bilgilerin yer aldığı dokümandır.
- 3.6.2.9. Form:** Usul ve Esaslar ile talimatlarda anlatılan işleri destekleyen, işlerin kim tarafından, ne zaman ve nasıl yapıldığının kaydedildiği dokümandır.
- 3.7. Dış Risk:** Şirketin kontrolü dışında gerçekleşen olaylar sonucunda ortaya çıkan risklerdir (Ör: Rakipler, yasa ve düzenlemeler, hissedarlar, politik, ekonomik, müşteri trendleri, değişim yönetimi, doğal afet, sektör vs.).
- 3.8. Doğal (Yapısal) Risk:** Riskler ilk tespit edildiğinde sahip oldukları risk seviyesidir. Olayların doğasında var olan riskleri anlatmak için kullanılan bir terimdir. Riskler hakkında herhangi bir önlem alınmaması durumunda risklerin seviyesini ifade eder.
- 3.9. Etki Puanı:** Riske ilişkin olayın meydana gelmesi durumunda oluşacak etki derecesidir.
- 3.10. Etkiyi Azaltma Aksiyonu (EAA):** Risklerin mevcuttaki etkilerinin azaltılmasına yönelik önlemlerdir.
- 3.11. İç Risk:** Doğrudan şirket tarafından kontrol edilebilecek olaylar sonucunda ortaya çıkan risklerdir (Ör: Operasyonel riskler, stratejik riskler, finansal riskler, itibar riskleri, uyum riskleri vs.).
- 3.12. İç Sistemler:** PTT A.Ş. İç Denetim, İç Kontrol ve Risk Yönetimi sistemleridir. İç Sistemler kapsamındaki Birimler, İç Denetim Birimi, İç Kontrol Birimi ve Risk Yönetimi Birimidir.
- 3.13. İSGYS:** OHSAS 18001 (45001) İş Sağlığı ve Güvenliği Yönetim Sistemidir.
- 3.14. Kabul Edilebilir Risk:** Şirketin, yasal zorunluluklara ve kendi politikalarına göre tahammül edebileceği düzeye indirilmiş risktir.
- 3.15. Kalan (Artık) Risk:** Riskin olasılığını ve etkisini azaltmak için kontrol faaliyetleri ve riske karşılık vermeyi kapsayan önlemler alındıktan sonra geriye kalan risktir.
- 3.16. Kalan (Artık) Risk Puanı:** Risk karşılama aksiyonu sonunda belirlenen olasılık ve etki puanlarının çarpımı sonucu ortaya çıkan puandır.
- 3.17. Kritik Risk Göstergesi:** Riskin izlenmesi ve erken uyarı amacıyla kullanılan göstergelerdir (anket sonuçları, performans verileri, şikâyetler vs.).
- 3.18. KYS:** ISO 9001 Kalite Yönetim Sistemidir.
- 3.19. Olasılığı Azaltma Aksiyonu (OAA):** Risklerin mevcuttaki olasılıklarını azaltmak için alınan önlemlerdir.
- 3.20. Olasılık Puanı:** Riske ilişkin olayın meydana gelmesi durumunda oluşacak olasılık derecesidir.
- 3.21. Risk:** Amaç ve hedeflerin gerçekleşmesine engel olabilecek ve kayıp yaratabilecek iç veya dış kaynaklı belirsiz durum veya olaylardır.
- 3.22. Risk Aksiyonu:** Riskten kaçınma, risk ihtimalinin ve etkilerinin azaltılması, riskin transfer edilmesi, paylaşılması veya riskin kabul edilmesine yönelik alınan önlemlerdir.

- 3.23. Risk Aksiyon Sorumlusu:** Risklerin önlenmesine yönelik faaliyetlerin gerçekleştirilmesinden sorumlu personeldir.
- 3.24. Risk Analizi:** Riskin tanımlanmasını, riskin ortaya çıkma nedenlerinin, olumsuz etkilerinin tespit edilmesi, bu nedenlerin ortaya çıkma olasılıklarının ve etki derecelerinin belirlenerek riskin önem derecesinin hesaplanmasını ifade eder.
- 3.25. Risk Değerlendirmesi:** Tehlikelerden/belirsizliklerden kaynaklanan riskin büyüklüğünü tahmin etmek ve mevcut kontrollerin yeterliliğini dikkate alarak riskin kabul edilebilir olup olmadığına ve risk önlemlerine karar vermek için kullanılan süreçtir.
- 3.26. Risk Değerlendirme Tablosu:** Başkanlık, Müşavirlik ve Birimler bazında mevcut/yeni risklerin, risklere ilişkin belirlenen risk önlemlerinin/kontrollerinin, risk puanlarının, öneri ve değerlendirmelerin yer aldığı QDMS programında tanımlı tablodur.
- 3.27. Risk Durum Raporu:** Risk ekipleri tarafından oluşturulan Risk Tanım Kartları, EAA-OAA Takip Tablosu, Risk Değerlendirme Formu ile mevcut durum ve önerileri içeren rapordur.
- 3.28. Risk Ekibi:** Başkanlık, Müşavirlik ve Birimlerde risk sorumlusu tarafından oluşturulan konusunda deneyimli en az üç kişilik ekiptir.
- 3.29. Risk İştahı/Risk Alma İsteği:** Yönetimin hedefleri belirlerken üstlenmeyi öngördüğü risk miktarıdır.
- 3.30. Risk Kategorisi:** Riskleri tanımlama, değerlendirme, ölçme ve izlemeye yardım eden tanımlı risk gruplarıdır. PTT A.Ş.'de Kurumsal Riskler aşağıdaki kategorilerde değerlendirilir.
- 3.30.1. Stratejik Riskler:** Şirketin kısa, orta veya uzun vadede belirlemiş olduğu stratejik hedeflerine ulaşmasını engelleyebilecek risklerdir.
- 3.30.2. Operasyonel Riskler:** Şirketin temel iş süreçlerini (operasyonlarını) yerine getirmesini engelleyebilecek risklerdir. Diğer bir deyişle Şirketin ürün ve hizmetlerinin uygunluğunu, müşteri memnuniyetini etkileyebilecek operasyonel faaliyetlerinden kaynaklı olası zararlarıdır.
- 3.30.3. Finansal Riskler:** Şirketin uygulamaları sonucunda oluşabilecek finansal kayıplara ilişkin risklerdir.
- 3.30.4. İtibar Riskleri:** Şirketin faaliyetlerindeki başarısızlıklar ya da mevcut yasal düzenlemelere uygun davranılmaması sonucunda söz konusu Şirkete duyulan güvenin azalması veya itibarının zedelenmesi ile ortaya çıkabilecek kayıptır.
- 3.30.5. Uyum Riskleri:** Şirketin yürürlükteki kanunlara, diğer hukuki düzenlemelere, etik kurallara, Şirket içi politika ve yönetmelikler gibi tanımlı kurallara uymaması halinde karşılaşılabilecek yasal müeyyideler ile kayıpları ifade etmektedir.
- 3.31. Risk Karşılama Aksiyonu/Yöntemleri:** Risk kayıplarını azaltmak üzere kaçınma, azaltma, transfer, paylaşma, kabullenme yöntemlerinden en az birini içeren faaliyetlerdir.
- 3.32. Risk Kütüğü:** PTT A.Ş.'nin önemli gördüğü ve üst yönetim tarafından takip edilen risklere ilişkin tanımlarının, açıklamalarının, olasılık, etki ve mevcut risk puanlarının, risklerin kabul edilebilir sınırlara çekilebilmesi için yürütülecek risk karşılama yöntemlerinin ve kontrollerinin, kalan risk

puanlarının, aksiyon sorumlularının, risk sorumlularının ve durum değerlendirme bilgilerinin yer aldığı belgedir.

- 3.33. Risk Matrisi:** Bir riskin gerçekleşme ihtimali ile ortaya çıkaracağı etki değerlendirilerek risklerin önem derecelerine göre konumlandırıldığı tablodur.
- 3.34. Risk Puanı:** Olasılık ve etki puanının çarpımı sonucu hesaplanan puandır.
- 3.35. Risk Puan Tablosu:** Etki Puanı ve Olasılık Puanı çarpımı sonucu oluşan Risk Puanlarını gösteren tablodur.
- 3.36. Risk Raporu:** Risk Yönetimi Birimi tarafından oluşturulan risk kütüğü, risk matrisi ile mevcut durum ve önerileri içeren rapordur.
- 3.37. Risk Sorumlusu:** Başkanlık, Müşavirlik ve Birimlerde en az Başkan veya dengi düzeydeki yöneticidir.
- 3.38. Risk Toleransı:** Hedeflerdeki değişkenliğin kabul edilebilir düzeyidir.
- 3.39. Risk Yöneticisi:** Risk Yönetimi Birim Sorumlusudur.
- 3.40. Risk Yönetimi Sistemi:** Şirketin, faaliyetlerinin kapsamı ve yapısı ile uyumlu ve değişen koşullara uygun, maruz kalınabilecek tüm risklerin tanımlanmasını, ölçülmesini, izlenmesini, kontrol edilmesini ve raporlanmasını sağlamak üzere oluşturulan etkin risk yönetim sistemidir.
- 3.41. Şirket/PTT A.Ş. :** Posta ve Telgraf Teşkilatı Anonim Şirketi'dir.
- 3.42. Geçersiz Doküman:** Yürürlükten kaldırılan dokümanın aslıdır.
- 3.43. Genel Müdür:** Posta ve Telgraf Teşkilatı Anonim Şirketi Genel Müdürüdür.
- 3.44. Genel Müdür Yardımcısı:** Posta ve Telgraf Teşkilatı Anonim Şirketi Genel Müdür Yardımcısıdır.
- 3.45. Görev Tanımı:** PTT A.Ş.'de İnsan Kaynakları tarafından belirlenmiş olan görev başlıklarında sorumlu olduğu pozisyonun tanımını, kapsamını ve uygulamadaki akışını düzenleyen dokümanlardır.
- 3.46. Hedef:** Amaçların gerçekleştirilebilmesine yönelik spesifik, ölçülebilir ve kısa dönemli aşama durumlarını oluşturur. Ulaşılması öngörülen çıktı ve sonuçların tanımlanmış bir zaman dilimi içinde nitelik ve nicelik olarak ifadesidir. Miktar, maliyet, kalite ve zaman cinsinden ifade edilebilir olması gerekmektedir. Bir amacı gerçekleştirmeye yönelik olarak birden fazla hedef belirlenebilir.
- 3.47. Kurumsal Değerler/İlkeler:** Şirketin davranışlarını belirleyen amaçlar ile hedeflerin geliştirilmesi ve yürütülmesine rehberlik eden faktörlerdir.
- 3.48. Misyon:** Şirketin varoluş gerekçesidir.
- 3.49. Plan:** Bir süreç için uygulanacak faaliyetleri, hedefleri, hedeflere ulaşmak için kullanılacak yöntem ve unsurları, işlem sıralarını, bu faaliyetlerin kontrol metotlarını, özelliklerini, kaynak ve ekipman ihtiyaçlarını, uygunsuz sonuçlarla karşılaşıldığında uygulanacak işlemleri gösteren dokümandır.
- 3.50. Prosedür:** Şirketin uygulamakta olduğu/uygulayacağı süreçleri etkileyen tüm aktivitelerle ilgili olarak sorumluları, iş akışlarını, bölümler arası ilişkileri belirleyen, kullanılacak formları ve talimatları açıklayan usul ve esaslardır. Prosedür, yürütülen faaliyetin amacı, kapsamı, sorumluları, uygulama alanı ve ilgili dokümanlar tanımlanarak hazırlanır. Prosedür; ne, nasıl, neden, nerede, ne zaman

yapılacak, kim tarafından hangi yöntemle kontrol edilecek ve değerlendirilecek, nasıl kaydedilecek ve izlenecek sorularının yanıtlarını açık ve kısa olarak belirtir.

- 3.51. Revizyon:** Yayınlanmış olan dokümanlarda saptanan bir uygunsuzluğun düzeltilmesi, uygulama değişikliğinin dokümanda tanımlanması yoluyla doküman üzerinde yapılan değişikliklerin tümüdür.
- 3.52. Sorumlu Birim:** Hedefin gerçekleştirilmesi için çalışacak olan birimdir.
- 3.53. Strateji:** İşletme amaçlarına ve hedeflerine ulaşabilmek için, işletme ve entegre yönetim sistemi politikaları çerçevesinde uygulanacak yol, yöntem ve araçlardır.
- 3.54. Üst Yönetim:** Merkez Teşkilatında Yönetim Kurulu Başkanı/Genel Müdür ile Genel Müdür Yardımcıları ile Birim Üst Yöneticilerini; Taşra Teşkilatında ise Başmüdürleri ifade eder.
- 3.55. Vizyon:** Şirketin arzu edilen geleceğidir.
- 3.56. Yayınlama:** Oluşturulan dokümanların tanımlanmış elektronik ortamda ilgililerin bilgilenmesine ve uygulamasına sunulmasıdır.
- 3.57. Yürürlük Tarihi:** Dokümanın yayınlanarak yürürlüğe girdiği tarihtir.

4. PRENSİPLER

- 4.1.** Tespit edilen riskler, idarenin hedefleri ile ilgili olmalıdır.
- 4.2.** Riskler, sistematik olarak ve önceden belirlenmiş yöntemlere göre tespit edilmelidir.
- 4.3.** Hedeflere ilişkin olarak tespit edilen riskler iç ve dış riskler olarak gruplandırılmalı ve hem iç hem de dış riskler kendi içinde alt gruplara ayrılmalıdır.
- 4.4.** Riskler tespit edildikten sonra bunların sahibi; kimin sorumluluğunda olduğu belirlenmeli ve risk kaydında bu bilgiye yer verilmelidir.
- 4.5.** Risk yönetimi dinamik bir süreç olduğundan yeni ortaya çıkan riskler tespit edilmeli ve mevcut risklerdeki değişiklikler sürekli takip edilmelidir.

5. SORUMLULUKLAR

Bu prosedürün uygulanmasından her kademedeki PTT A.Ş. çalışanı sorumludur. Tüm çalışanlar risk yönetimini etkiler. Risklerin belirlenmesi veya değerlendirilmesinde kullanılan bilgileri oluşturabilirler.

5.1. Risk Yönetimi Sisteminde Yer Alan Komiteler, Ekipler, Birimler ve Sorumlulukları

5.1.1. Yönetim Kurulu

- 5.1.1.1.** Yönetim Kurulu, risk yönetimi süreçlerinin yönlendirilmesi ve izlemesini teminen bu fonksiyonun iletişimini sağlamak üzere icracı fonksiyonlarla ilintisi olmayan en az bir üyesini risk yönetiminden sorumlu üye olarak görevlendirmekle,

5.1.1.2. Riskin belirlenmesi, ölçülmesi, izlenmesi, kontrol edilmesi ve raporlanması evrelerinden oluşan risk yönetimi sürecinin yönlendirilmesi ve izlenmesini teminen kendisine bağlı alt komite niteliğinde olmak üzere risk yönetiminden sorumlu Yönetim Kurulu üyesinin başkanlığında çalışacak risk değerlendirme komitesi üyelerini belirlemekle,

5.1.1.3. Risk strateji ve politikasını belirlemekle,

5.1.1.4. Risk iştahını belirlemekle,

5.1.1.5. Risklerin değerlendirmesi çalışmalarında görevlendirilen kişi veya kişilerin görevlerini yerine getirmeleri amacıyla araç, gereç, mekân ve zaman gibi gerekli bütün ihtiyaçlarının karşılanmasını sağlamakla,

Sorumludur.

5.1.2. Denetim Komitesi

Yönetim Kurulu tarafından, kendi üyeleri arasından seçilen risk yönetiminden sorumlu üye ile icrai görevi bulunmayan diğer bir üye olmak üzere en az iki üyeden oluşan ve bu prosedür kapsamındaki Risk Yönetiminden sorumlu komitedir.

5.1.2.1. Şirketin karşı karşıya olduğu risklerin etkili bir şekilde yönetilip yönetilmediğini takip etmekle,

5.1.2.2. Risk Yönetim Sistemi ile ilgili görüş, öneri, talep ve ihtiyaçları değerlendirmek ve gereğini sağlamakla,

5.1.2.3. Risk izleme fonksiyonunu etkin bir şekilde yerine getirmeyi sağlamak üzere gerekli görüldüğünde ilgili birimlerden bilgi, görüş ve rapor talep etmekle ve gerekli görevlendirmeleri yapmakla,

5.1.2.4. Risk Yönetim Sisteminin sürekli iyileştirilmesini ve geliştirilmesini sağlamakla, Sorumludur.

5.1.3. Risk Değerlendirme Komitesi

Risk Değerlendirme Komitesi, Yönetim Kurulunun icracı fonksiyonlarla ilintisi olmayan risk yönetiminden sorumlu üyesi başkanlığında en az bir Genel Müdür Yardımcısı, I. Hukuk Müşaviri, Daire Başkanları ve Birim Yöneticilerinden oluşan en az yedi kişilik komitedir.

5.1.3.1. Şirketin stratejik amaç ve hedeflerine ve bunların altında yer alan faaliyetlere yönelik olarak Risk Yönetim Biriminin koordinasyonunda tespit edilen riskleri Başkanlıkların/Birimlerin süreçleri/faaliyetleri ile ilişkilendirmekle,

5.1.3.2. Risk Yönetimi Birimince hazırlanan tüm riskleri değerlendirmekle, risklerin önlenmesi ve kabul edilebilir risk seviyesine çekilmesi için risk karşılama aksiyonlarını ve kontrol önlemlerini planlamakla,

5.1.3.3. Risk aksiyon sorumlularını belirlemekle,

5.1.3.4. Mevcut risklerin önlenmesi için başlatılan aksiyonların ilerleme durumunu incelemekle ve eğitim

Doküman No

RYB.PR01.0

9.10.2018

ihtiyacı vb. talepleri ve önerileri değerlendirmekle,

5.1.3.5. Tüm değerlendirmelerin ilgili tablolara eklenmesini sağlamakla, ihtiyaç duyulduğunda Risk Değerlendirme Komitesi altında çalışma grupları oluşturmakla,

5.1.3.6. Her yıl, üçer aylık dönemler halinde hazırlanan Risk Değerlendirme Formunda yer alan risklerden önemli ve acil önlem alınması gereken riskleri, risk karşılama aksiyonları ve iş planları ile gerçekleşme durumlarını, Risk Yönetimine ilişkin önerileri, talepleri ve diğer hususları belirlemekle,

5.1.3.7. Üst Yönetim ve Denetim Komitesi tarafından verilen görevleri yerine getirmekle,

Sorumludur.

5.1.3.8. Risk Değerlendirme Komitesinin koordinasyonu ve sekreteryası Risk Yönetimi Birimi tarafından gerçekleştirilir.

5.1.3.9. Risklerin değerlendirmesi çalışmalarında görevlendirilen kişi veya kişiler PTT A.Ş. tarafından sağlanan bilgi/belgeleri korur ve gizli tutar.

5.1.4. Risk Yönetimi Birim Sorumlusunun Görev, Yetki ve Sorumlulukları

Risk Yönetimi Birim Sorumlusu Risk Yöneticisi olup görev, yetki ve sorumlulukları şunlardır;

5.1.4.1. Bu esasların 5.1.5. maddesinde belirtilen görevleri yürütmek,

5.1.4.2. Risk yönetimi personelinin çalışmalarını düzenlemek ve denetlemek,

5.1.4.3. Risk yönetimi personelinin görev, yetki ve sorumluluklarının gerektirdiği niteliklere haiz olup olmadıklarını denetlemek,

5.1.4.4. Risk yönetimi personelinin mesleki bilgi, beceri ve yeteneklerinin geliştirilmesine yönelik eğitim programlarını hazırlamak,

5.1.4.5. Risk Yönetim Birimini temsil etmek,

5.1.4.6. Operasyonel işlemler dışında Denetim Komitesi tarafından uygun görülecek diğer işleri yapmak.

5.1.4.7. Birim Sorumlusu; Birimin yönetiminden ve risk yönetimi personelinin bu esaslar çerçevesinde çalıştırılmasından, Yönetim Kuruluna karşı sorumludur.

5.1.5. Risk Yönetimi Birimi

Risk Yönetimi Birimi, Risk Yönetimi Birim Sorumlusu ile yeteri kadar Risk Yönetimi Personelinden oluşur. Birim doğrudan Yönetim Kuruluna bağlıdır. Yönetim Kurulu bu yetkisini Denetim Komitesi kanalıyla kullanır. Şirketin Risk Yönetimi Sisteminin yürütülmesinden, sistemin sürekli iyileştirilmesinden ve geliştirilmesinden sorumlu birimdir.

Birim;

Doküman No
RYB.PR01.0

9.10.2018

- 5.1.5.1.** Şirketin risk yönetimi sistemini bütün olarak dizayn etmekle,
- 5.1.5.2.** Risk Yönetimi stratejileri esas alınarak yönetimin görüşleri doğrultusunda Risk Yönetimi ilkelerini ve uygulama esaslarını içeren Risk Prosedürünü hazırlamak, güncellemek ve onaya sunmakla,
- 5.1.5.3.** Onaylanan Risk Prosedürünün tüm teşkilata duyurulmasını sağlamak ve uygulamaları takip etmekle,
- 5.1.5.4.** Gerekli olduğu durumlarda eğitim ve talimat, rehber, el kitapçığı, vb. dokümanların hazırlanmasını sağlamakla,
- 5.1.5.5.** Şirketin faaliyetlerinin kapsamı, yapısıyla uyumlu ve değişen koşullara uygun, maruz kalınabilecek tüm riskleri, ilgili birimlerle koordineli olarak tespit etmek, tanımlamak, çeşitli model ve/veya analizler yardımıyla ölçmek, izlemek ve raporlamakla,
- 5.1.5.6.** Risk izleme fonksiyonunu etkin bir şekilde yerine getirmeyi sağlamak üzere gerekli görüldüğünde ilgili birimlerden bilgi, görüş ve rapor talep etmekle,
- 5.1.5.7.** Sayısallaştırılabilen risklere ilişkin üst yönetim ve denetim komitesi ile birlikte risk iştahını belirleyerek Yönetim Kuruluna sunmakla,
- 5.1.5.8.** Kontrol edilebilen ve kontrol edilemeyen riskleri azaltmak amacıyla uyarılarda bulunmak, gerekli tedbirleri almak, aldirtmak ve raporlamakla,
- 5.1.5.9.** Yılda bir kez risk kütüğünü, mevcut durum, planlama ve önerileri içeren Risk Yönetim Raporunu hazırlamak ve Denetim Komitesi ile Yönetim Kuruluna sunmakla,
- 5.1.5.10.** İç Sistemlere ilişkin olarak önerilerde bulunmak, maruz kalınan risklerin değerlendirilmesi sürecinde İç Sistemler kapsamındaki Birimler ile eşgüdüm içinde çalışmakla,
- 5.1.5.11.** Risk Yönetimine ilişkin güncel mevzuatın takibini yapmakla,
- 5.1.5.12.** Risk Yönetim Sistemi ile ilgili her türlü koordinasyon faaliyetini yürütmekle, sistemin sürekli iyileştirilmesini ve geliştirilmesini sağlamakla,
- Sorumludur.
- 5.1.5.13.** Bilgi Güvenliği Yönetim Sistemi, Kalite Yönetim Sistemi, İş Sağlığı ve Güvenliği Sistemi ve Çevre Yönetim Sistemine yönelik risk ve değerlendirmeler Entegre Yönetim Sistemi Daire Başkanlığınca takibi yapılarak Risk Yönetimi Birimine aktarılır.

5.1.6. Risk Yönetimi Birimi Personeli

- 5.1.6.1.** PTT A.Ş.'nin iç ve dış risklerinin olasılıklarını ve etkilerini çeşitli yöntemlerle tespit etmek, riskleri önceliklendirmek, risk aksiyonlarını (Kaçınma, azaltma, transfer, paylaşma, kabul) belirlemek, gözden geçirmek ve raporlamakla,
- 5.1.6.2.** PTT A.Ş. bünyesinde risk yönetimi faaliyetlerinin teknoloji destekli yürütülmesine ilişkin araştırmalar

yapmakla,

5.1.6.3. Risk Kütüğünü, mevcut durum, planlama ve önerileri içeren Risk Yönetim Raporunu hazırlamakla,

5.1.6.4. PTT A.Ş. Risk Yönetim Sistemi kapsamında belirlenen risk kütüğünün uygulanmasını sağlamak, sonuçlarını izlemek ve değerlendirmekle,

5.1.6.5. Birim Sorumlusuna bilgi vermek kaydıyla ilgili birimlerden görev alanları çerçevesinde her türlü bilgi, veri ve belgeyi talep etme, inceleme, araştırma yapmakla,

5.1.6.6. Verilen talimatları yerine getirmekle görevli olup Birim Sorumlusuna karşı sorumludur.

5.1.7. Risk Yönetimi Yönetim Hizmetleri Şefliği

5.1.7.1. Birimin tüm gelen ve giden yazışmalarının kayıt, dosyalama ve muhafaza işlerini, haberleşme ve ulaşım işlevlerini üstlenmekle,

5.1.7.2. Birim bünyesinde personel işlemlerine ilişkin ilgili kayıtların tutulmasını sağlamakla,

5.1.7.3. Birimin yıllık bütçesini hazırlamak ve tahakkuk işlerini yürütmekle,

5.1.7.4. Birim için gerekli araç, gereç ve malzemenin temini ile ilgili hizmetleri yürütmekle,

5.1.7.5. Birim sorumlusu tarafından verilecek diğer görev ve işlemleri yapmakla,

Görevlidir.

5.1.8. Risk Sorumlusu

Risk Sorumlusu;

5.1.8.1. Risk ekibine başkanlık yapmak ve risk ekibini düzenli olarak toplamakla,

5.1.8.2. Sorumluluk alanındaki Risk Tanım Kartlarını, Risk Değerlendirme Formunu, EAA-OAA Takip Tablosunu QDMS üzerinden doldurmakla, risk kütüğünden çıkarılması veya risk kütüğüne eklenmesi öngörülen riskleri içeren Risk Durum Raporunun Risk Ekiplerince hazırlanmasını sağlamak ve söz konusu tablo, kart ve raporu her yılın Mart, Haziran, Eylül ve Aralık ayı sonunda olmak üzere üç ayda bir risk yönetimi birimine sunmakla,

5.1.8.3. Risk Yönetimi Birimi tarafından yapılan toplantılarda alınan kararları ve verilen görevleri yerine getirmekle,

5.1.8.4. Risk karşılama aksiyonlarının hazırlanan iş planlarına uygun olarak yürütülmesini sağlamakla ve aksiyon sorumluları ile ihtiyaç duyduğunda toplantı düzenlemekle,

5.1.8.5. Sorumluluk alanında oluşan yeni risklerin tanımlanmasını ve risklerin analiz edilmesini sağlamakla,

Sorumludur.

5.1.9. Risk Ekibi

Risk Ekibi;

5.1.9.1. Risk sorumlusu tarafından yapılacak toplantılara katılmak ve verilen görevleri yerine getirmekle,

5.1.9.2. Görevli bulundukları birimlerdeki riskleri tanımlamakla,

5.1.9.3. Risklerin etki ve nedenleri ile risk kategorilerinin belirlenmesini ve mevcut risk puanlarının hesaplanmasını içeren risk analizini yapmakla,

5.1.9.4. Tespit edilen risklere uygun önlemlerin, kritik risk göstergelerinin ve kontrollerin belirlenmesine ilişkin çalışma yapmakla,

5.1.9.5. Sorumluluk alanındaki Risk Tanım Kartlarını, Risk Değerlendirme Formunu, EAA-OAA Takip Tablosunu QDMS üzerinden doldurmakla, risk kütüğünden çıkarılması veya risk kütüğüne eklenmesi öngörülen riskleri içeren Risk Durum Raporunu ve söz konusu tablo, kart ve raporu her yılın Mart, Haziran, Eylül ve Aralık ayı sonunda olmak üzere üç ayda bir hazırlamakla,

5.1.9.6. Risk karşılama aksiyonlarına ait iş planlarının Aksiyon Sorumlularınca oluşturulmasını sağlamakla ve belirlenen periyodlarla gerçekleşme durumlarını takip etmekle,

5.1.9.7. Belirlenen periyodlarla risklerdeki gelişmeleri izlemekle, değerlendirmeleri yaparak kalan (artık) risk puanlarını hesaplamakla,

Sorumludur.

5.1.10. Risk Aksiyon Sorumlusu

Risk aksiyon sorumluları Risk Değerlendirme Komitesi tarafından belirlenir.

Risk aksiyon sorumlusu;

5.1.10.1. Risklerin önlenmesi, etki ve olasılıklarının azaltılmasına yönelik aksiyonların gerçekleştirilmesini sağlamakla,

5.1.10.2. Sorumluluk alanındaki aksiyonlara ait iş planlarını hazırlamak ve iş planlarına uygun olarak gerçekleşme durumlarını, varsa karşılaşılan sorunları, görüş ve önerilerini aylık periyodlarla Risk Sorumlusuna iletmekle,

5.1.10.3. Gerekli olduğunda sorumlu olduğu aksiyonlara ilişkin revizyonları yapmakla,

5.1.10.4. Risk Sorumlusu tarafından düzenlenen toplantılara katılmakla,

5.1.10.5. Aksiyon alındıktan sonra Risk Puan Tablosunu kullanarak Kalan Risk Puanını hesaplamak ve EAA-OAA Tablosuna işlemekle,

5.1.10.6. İç Kontrol Birimi ile koordinasyonlu çalışmakla,

Doküman No
RYB.PR01.0

9.10.2018

5.1.10.7. Sorumludur.

6. UYGULAMA

6.1. Risk Yönetimi Süreci:

Risk yönetimi süreci, Şirketin hedeflerinin gerçekleştirilebilmesi için Yönetime makul güvence sağlamak amacıyla risklerin tanımlanması, risklerin analiz edilmesi, önceliklendirilmesi, risk kontrollerinin ve karşılama yöntemlerinin belirlenmesi ile gerekli önlemlerin alınması, risklerin sürekli izlenmesi, gözden geçirilmesi ve yeniden değerlendirilmesinden oluşan bir süreçtir.

Risk yönetimi sürecinin temel unsurları;

6.1.1. Risklerin belirlenmesini,

6.1.2. Risklerin analiz edilmesini,

6.1.3. Risklerin değerlendirilmesi ve önceliklendirilmesini,

6.1.4. Kontrollerin ve Riskleri karşılama yöntemlerinin belirlenmesini,

6.1.5. Risk yönetim sürecinin sürekli izlenmesini, gözden geçirilmesini ve yeniden değerlendirilmesini,

6.1.6. Bilgi ve iletişimin sağlanmasını kapsar.

6.2. Risklerin Belirlenmesi:

6.2.1. Şirket riskleri; stratejik, operasyonel, itibar, uyum ve finansal riskler olmak üzere beş kategoriye ayrılır.

Riskler, risk kategorilerine göre aşağıdaki hususlar dikkate alınarak belirlenir:

6.2.1.1. Stratejik amaç ve hedeflerin gerçekleşmesini engelleyen durumlar,

6.2.1.2. İş süreçleri sonucunda doğabilecek aksaklık, başarısızlık, yolsuzluk, usulsüzlük ve finansal kayıplara ilişkin durumlar,

6.2.1.3. Şirkette yürütülen projelerin gerçekleşmesini engelleyen durumlar,

6.2.1.4. Yatırım değerlendirme, iş modelleri, bütçe planlama gerçekleşmelerini engelleyen durumlar,

6.2.1.5. Organizasyonel yapıdan kaynaklanan olumsuzluklara ilişkin durumlar,

6.2.1.6. EYS hedeflerinin gerçekleşmesini engelleyen durumlardır.

6.2.2. Riskler belirlenirken aşağıdaki kaynaklardan faydalanılır:

6.2.2.1. Mevcut kontroller ve etkinliği,

6.2.2.2. Geçmiş veriler ve deneyimler,

6.2.2.3. Süreç haritaları ve iş akış şemaları,

- 6.2.2.4. Stratejik Plan ve planlama içinde yer alan analizler (Güçlü Zayıf Fırsatlar Tehditler (GZFT), sektör analizi v.b),
- 6.2.2.5. Süreç performans göstergeleri,
- 6.2.2.6. Düzeltici faaliyetler,
- 6.2.2.7. Rutin/rutin olmayan faaliyetlerin değerlendirilmesi,
- 6.2.2.8. Diğer yönetim sistemlerine ilişkin veriler,
- 6.2.2.9. Finansal raporlar,
- 6.2.2.10. Sektördeki diğer kuruluşlarda yaşanan kayıplara ilişkin bilgiler,
- 6.2.2.11. Sektördeki kuruluşlara ve diğer kuruluşlara yapılan ziyaret raporları,
- 6.2.2.12. Denetim raporları,
- 6.2.2.13. Anketler,
- 6.2.2.14. Yasal Mevzuat,
- 6.2.2.15. Diğer raporlar.

6.2.3. Riskler tespit edilirken beyin fırtınası vb. yöntemler kullanılır.

6.3. Risklerin Analiz Edilmesi:

- 6.3.1. Tanımlanan her bir riskin nedenleri ve meydana gelmesi durumunda oluşturacağı etkiler belirlenir, riskin nedenleri riskin ortaya çıkma olasılığı ile ilişkilidir.
- 6.3.2. Risk yönetimi kapsamında tüm birimlerde oluşturulan risk ekipleri tarafından riskler belirlenerek QDMS yazılımındaki ilgili tablo ve formlara işlenir. Riskler bu ekipler tarafından üç ayda bir gözden geçirilerek, QDMS yazılımında güncellenir.
- 6.3.3. Risk ekipleri tarafından hazırlanan risk analizleri Risk Yönetimi Birimi tarafından değerlendirilir, risklerin uygunluğu ve alınacak önlemlerin etkinliğine göre risk analizine son hali verilir ve Risk Değerlendirme Formuna kaydedilir. Söz konusu forma acil önlem alınması gereken ve Şirket için önemli olan riskler işlenir. Risk Değerlendirme Formu, Risk Yönetim Birimi tarafından Risk Değerlendirme Komitesine sunulur.
- 6.3.4. Risk Değerlendirme Komitesi risklerin azaltılması, ortadan kaldırılması, transfer edilmesi ve yönetilmesi ile ilgili kararları alır, gerekli aksiyonları kontrol eder ve öncelikleri belirler.
- 6.3.5. Risk Yönetim Birimi tarafından Risk Yönetim Komitesinde alınmasına karar verilen aksiyonlar İç Kontrol Birimine aktarılır. İç Kontrol Birimi tarafından, belirlenen sürede QDMS yazılımı üzerinden ilgili risk aksiyon sorumlularınca aksiyon başlatılması sağlanır.

6.3.6. Aksiyonlarla ilgili raporlar QDMS yazılımı üzerinden Risk Yönetimi Birimi ve İç Kontrol Birimi tarafından takip edilir. Bu işlem riskler azaltılana, ortadan kaldırılana veya transfer edilene kadar devam ettirilir. Söz konusu işlemler ile risklerin sürekli izlenmesi sağlanır.

6.4. Risk Değerlendirme Metodolojisi

6.4.1. Risk Değerlendirmesi

Risk değerlendirmesi için aşağıdaki adımlar uygulanır:

6.4.1.1. Şirketin stratejik amaçları ve hedefleri ile ilgili faaliyetler, Birim iş süreçleri, Birim faaliyetleri, yeni iş modelleri ile projeler belirlenir ve her biri için risk tanımlamaları yapılır,

6.4.1.2. Tanımlanan her bir riskin nedenleri ve meydana gelmesi durumunda oluşturacağı etkiler belirlenir,

6.4.1.3. Risk Değerlendirmesi Tablo 1'e uygun olarak 5x5 matrisi kullanılarak gerçekleştirilir,

6.4.1.4. Risk Puanı= Olasılık x Etki formülü kullanılarak hesaplanır,

6.4.1.5. Risk değerlendirme sonuçları Risk Değerlendirme Formuna kaydedilir,

6.4.1.6. Her riskin olasılığı ve etkisi Tablo 1'deki sınıflamaya göre belirlenir ve risk puanı bulunur.

6.4.2. Risk değerlendirmesi sonucunda aşağıdaki risk aksiyon seçenekleri uygulanır:

6.4.2.1. Riskin kabulü,

6.4.2.2. Riskten kaçınma,

6.4.2.3. Riskin transferi,

6.4.2.4. Artık risk onayı (Artık risk onayı Risk Yönetim Komitesi ve Üst Yönetim tarafından gerçekleştirilir),

6.4.2.5. Riski azaltma, hafifletme,

6.4.2.6. Gözden geçirme ve izleme.

6.4.2.7. Yapılan değerlendirmeler QDMS yazılım programına işlenir,

6.4.2.8. Bilgi Güvenliği Yönetim Sistemi, Kalite Yönetim Sistemi, İş Sağlığı ve Güvenliği Sistemi ve Çevre Yönetim Sistemine yönelik risk ve değerlendirmeler Entegre Yönetim Sistemi Daire Başkanlığınca oluşturulan prosedür kapsamında yapılarak Risk Yönetimi Birimine raporlanır.

6.4.2.9. Risk Yönetimi Birimince QDMS programından alınan veriler Risk Değerlendirme Komitesine sunulur, Komite tarafından yapılan değerlendirme sonucu;

6.4.2.9.1. Tablo 2'de yer alan Risk Değerlendirme Matrisindeki açıklamalara uygun riskler önceliklendirilir,

6.4.2.9.2. Çok düşük/düşük riskler izleme ve kontrol sürecine alınır,

6.4.2.9.3. Orta, Yüksek/Çok Yüksek Riskler hakkında Risk Yönetimi Birimince hazırlanan rapor Denetim

Doküman No

RYB.PR01.0

9.10.2018



Komitesi üzerinden Yönetim Kurulu'na sunulur. Yönetim Kurulu kararı doğrultusunda izlenmesi gereken riskler izleme ve kontrol sürecinde takip edilir.

Risk Değerlendirme Tablosu

Puan	OLASILIK		Puan	ETKİ				
				5	4	3	2	1
	Sıklık (İşlem Frekansı)	Olasılık Tanımı/ Derecesi	RİSK DERECESESİ	Operasyonel (Servis ve Hizmet Etkisi)	İtibar	Uyum (Hukuki Düzenlemeler ve Mevzuata Uyum)	Finansal	Stratejik
5	Günlük veya daha sık; Yılda 250 kereden fazla	Benzer olaylarla çok sık karşılaşılmaktadır. Çok yüksek olasılık.	Çok Yüksek (OPxEP=25)	Şirket hizmet ve faaliyetlerinin 24 saatten daha uzun süre ile aksaması. Hizmetin durma seviyesine gelmesi.	Şirket değerini önemli derecede etkileyecek itibar kaybı. Ulusal medyada uzun süre yer alabilir.	Hukuki zorunluluklar veya regülasyon düzenlemelerine uzun süreli ve giderilmeyen uyumsuzluk ve bunun sonucu olarak Şirket hakkında cezai işlem yapılması.	Mali sonuçları çok büyük boyutta etkiler.	Şirket stratejik planındaki hedefleri tamamen güncelleme ihtiyacı doğuracak şekilde etkileyecek bir olay (politik veya ekonomik değişimler, personel kayıpları, savaş-terör veya afet durumları vb.) meydana gelmesi.
4	Haftalık; Yılda 52 kere	Benzer olaylarla sık karşılaşılmaktadır. Yüksek olasılık.	Yüksek (15<OPxEP<20)	Şirket hizmet ve faaliyetlerinin 8 saatten çok 24 saatten az süre ile aksaması. Hizmetin sunulmasında büyük boyutta aksama meydana gelmesi.	Konunun yazılı ve görsel basında gündeme gelecek şekilde itibari zararlarının olması.	Hukuki zorunluluklar veya regülasyon düzenlemelerine uzun süreli ve giderilmeyen uyumsuzluk ve bunun sonucu olarak Şirket hakkında idari işlem başlatılması.	Mali sonuçlara etkisi önemli derecededir.	Şirket stratejik planındaki hedefleri önemli ölçüde güncelleme ihtiyacı doğuracak şekilde etkileyecek bir olay (politik veya ekonomik değişimler, personel kayıpları, savaş-terör veya afet durumları vb.) meydana gelmesi.
3	Aylık; Yılda 12 kere	Benzer olaylarla ara sıra karşılaşılmaktadır. Orta dereceli olasılık.	Orta (5<OPxEP<12)	Şirket hizmet ve faaliyetlerinin 4 saatten çok, 8 saatten az süre ile aksaması. Hizmetin sunulmasında telafi edilebilir düzeyde aksaklık yaratması.	Konu hakkında hukuki takip başlatılması. Yerel medyada kısa sürede yer alabilir. Kamuoyunun dikkatini çekebilir.	Şirketin stratejik ve ticari gerçekleri ile uyumsuz regülasyon düzenlemelerin oluşması.	Mali sonuçlara etkisi orta düzeydedir.	Şirket stratejik planındaki hedefleri kısmi derecede güncelleme ihtiyacı doğuracak şekilde etkileyecek bir olay (politik veya ekonomik değişimler, personel kayıpları, savaş-terör veya afet durumları vb.) meydana gelmesi.
2	3 ayda bir; Yılda 4 kere	Benzer olaylarla nadiren karşılaşılmaktadır. Düşük / Küçük Olasılık	Düşük (1<OPxEP<4)	Şirket hizmet ve faaliyetlerinin 1 saatten çok, 4 saatten az süre ile aksaması.	Konu hakkında diğer düzenleyici Kurum ve kuruluşların bilgisi olmasını gerektirecek şekilde itibari kayıpların olması.	Hukuki zorunluluklar veya regülasyon düzenlemelerine uyumsuzluğun kolaylıkla giderilebileceği durumlar.	Mali sonuçları etkilemesi ihtimali düşüktür.	Şirket stratejik planındaki hedefleri hissedilecek fakat güncelleme ihtiyacı doğurmayacak şekilde etkileyecek bir olay (politik veya ekonomik değişimler, personel kayıpları, savaş-terör veya afet durumları vb.) meydana gelmesi.
1	Yıllık; Yılda 1 kere veya daha az	Geçmişte benzer bir olayla karşılaşılmamıştır. Çok düşük / Küçük olasılık.	Çok Düşük (OPxEP=1)	Şirket hizmet ve faaliyetlerinin 1 saatten daha kısa süre ile aksaması.	Konu hakkında ilgili birim üst yönetiminin bilgisi olmasını gerektirecek kayıplar.	Hukuki zorunluluklar veya regülasyon düzenlemelerine uyumsuzluğun kolaylıkla giderilebileceği durumlar.	Mali sonuçlara etkisi yok.	Şirket stratejik planındaki hedefleri minimum/hissedilmeyecek şekilde etkileyecek bir olay (politik veya ekonomik değişimler, personel kayıpları, savaş-terör veya afet durumları vb.) meydana gelmesi.

Risk Değerlendirme Matrisi

RİSK MATRİSİ		ETKİ PUANI				
		ÇOK DÜŞÜK (1)	DÜŞÜK (2)	ORTA DERECE (3)	YÜKSEK (4)	ÇOK YÜKSEK (5)
OLASILIK PUANI	ÇOK DÜŞÜK (1)	ÇOK DÜŞÜK (ÖNEMSİZ) 1	DÜŞÜK 2	DÜŞÜK 3	ORTA 4	ORTA 5
	DÜŞÜK (2)	DÜŞÜK 2	DÜŞÜK 4	ORTA 6	ORTA 8	ORTA 10
	ORTA DERECE (3)	DÜŞÜK 3	ORTA 6	ORTA 9	ORTA 12	YÜKSEK 15
	YÜKSEK (4)	DÜŞÜK 4	ORTA 8	ORTA 12	YÜKSEK 16	YÜKSEK 20
	ÇOK YÜKSEK (5)	ORTA 5	ORTA 10	YÜKSEK 15	YÜKSEK 20	ÇOK YÜKSEK (TOLERE EDİLEMEZ) 25

Tabloya göre Derecelendirme Esasları aşağıdaki gibidir:

- 1) Çok Yüksek Risk (kabul edilemez):** Risk puanı 25 puan olan riskler çok yüksek risk olarak tanımlanır. Bu gruptaki riskler denetim altında tutulur ve acilen önlem alınmalıdır.
- 2) Yüksek Risk:** Risk puanı 15 ile 25 puan arasındaki riskler yüksek risk olarak tanımlanır. Mutlaka iyileştirme yapılmalıdır. İyileştirme yapılırken, alınacak geçici önlemlerle faaliyet devam ettirilebilir.
- 3) Orta Risk (Dikkate Değer):** Etki puanı 4 olan riskler dâhil risk puanı 5 ile 12 puan arasındaki riskler orta risk olarak tanımlanır. Bu gruptaki riskler denetim altında tutulur ve önlem tanımlanabilir. İyileştirme yapılması mali ve teknolojik imkânlar çerçevesinde değerlendirilir. Uygun bulunan konularda iyileştirme yapılır.
- 4) Düşük Risk (Kabul Edilebilir):** Etki puanı 4 olanlar hariç risk puanı 1 ile 4 puan arasındaki riskler düşük risk olarak tanımlanır. İyileştirme çalışması yapılmasında fayda olmakla birlikte yapılmasa da faaliyetlerin devam ettirilmesi büyük risk taşımaz.
- 5) Çok Düşük (Önemsiz Risk):** Risk Puanı 1 olan risklerdir. Ek iyileştirme çalışmasına gerek yoktur.

Yönetim tarafından belirlenmiş olan kabul edilebilir risk seviyesi uyarınca, hesaplanan risk düzeylerinin kabul edilebilir olup olmadığına karar verilerek, tespit edilmiş olan kriterlere göre iyileştirme gereklilikleri belirlenir. Kabul edilebilir risk seviyesinin tespit edilmesi sırasında PTT A.Ş.'nin politikası ve amacı göz önünde bulundurulur.

Risklerin analiz edilmesi ve önceliklendirilmesine ilişkin yapılanlar sisteme işlenir, risklerle ilgili risk karşılama aksiyon planları oluşturulur.

Aksiyon planlarında tamamlanan risk karşılama aksiyonları sonucunda oluşan olasılık ve etki puanları doğrultusunda yeniden hesaplanan risk puanlarına göre kalan (artık) riskler, risk matrisinde ilgili alanda konumlandırılır. Kalan (artık) risk puanına göre yeniden değerlendirme yapılır.

